

《概论》第4章详细介绍了数据库安全性问题和实现技术。计算机系统安全以及数据库系统安全是信息安全的重要内容。

4.1 基本知识点

数据库的安全性与计算机系统的安全性是紧密联系的,计算机系统的安全性问题可分为三大类:技术安全类问题、管理安全类问题和政策法律类问题。本章讨论数据库技术安全类问题,即讨论从技术上如何保证数据库系统的安全性。

① 需要了解的:了解什么是计算机系统安全性问题、什么是数据库的安全性问题、威胁数据库安全性的因素有哪些;了解 TCSEC 和 CC 标准的主要内容。

② 需要牢固掌握的:掌握 C2 级 DBMS、B1 级 DBMS 的主要特征;掌握 DBMS 提供的安全措施,包括用户身份鉴别、自主存取控制和强制存取控制机制、视图技术和审计技术、数据加密存储和加密传输等。

③ 需要举一反三的:使用 SQL 中的 GRANT 语句和 REVOKE 语句来实现自主存取控制。

④ 难点:在强制存取控制机制中,确定主体能否存取客体的存取规则。读者要理解并掌握制定该存取规则的原因,特别是关于主体写客体的规则。

4.2 习题解答和解析

1. 什么是数据库的安全性?

【解析】当今,数据已成为一个部门、企业,乃至一个国家的重要资源,数据库中存放着海量数据,其重要性决定了数据库安全性是数据库系统的主要技术指标。

数据库的安全性是指保护数据库,以防不合法使用所造成的数据泄露、篡改或破坏。

2. 举例说明对数据库安全性产生威胁的因素。

【解析】请读者列出自己在生活和工作中遇到的、听到的实际案例。

3. 试述实现数据库安全性控制的常用方法和技术。

【解析】请认真阅读并理解《概论》第4章图4.2“数据库管理系统的安全性控制模型示例”。该模型清晰地展示了从用户登录数据库开始，在事前一事中一事后的全过程中数据库系统常用的安全性控制方法和技术。主要有：

① 用户身份鉴别：系统提供多种方式让用户标识自己的名字或身份。用户要使用数据库系统时，需由系统进行核对，通过鉴定后才可以使用数据库。

② 入侵检测：用户进入数据库系统时，系统依据预先设置的检测规则实时进行入侵分析，若发现入侵情况，则实时进行处理。

③ 多层存取控制：系统提供用户权限定义和合法权限检查功能，用户只有获得某种权限才能访问数据库中的某些数据。控制机制主要有自主存取控制和强制存取控制。

④ 视图机制：为不同的用户定义不同的视图。通过视图机制，向无权存取的用户隐藏应保密的数据，从而自动对数据提供一定程度的安全保护。

⑤ 审计：建立审计日志，自动记录用户对数据库的所有操作并放入审计日志，审计员可以利用审计信息，重现导致数据库现有状况的一系列事件，找出非法存取数据的人员、时间和内容等。

⑥ 存储保护和传输加密保护：对存储和传输的数据进行加密处理，从而阻止不知道解密算法的人获知数据的内容。

4. 什么是数据库中的自主存取控制方法和强制存取控制方法？

【解析】自主存取控制方法：定义各个用户对不同数据对象的存取权限。当用户访问数据库时，首先检查用户的存取权限，防止不合法用户对数据库的存取。SQL 主要通过 GRANT 语句和 REVOKE 语句实现自主存取控制。

自主存取控制中“自主”的含义是：用户可以将自己拥有的存取权限“自主”地授予别人，即用户具有一定的“自主”权。

强制存取控制方法：每一个数据对象被（强制地）标以一定的密级，每一个用户也被（强制地）授予某一个级别的许可证。系统规定只有具备某一许可证级别的用户才能存取某一个密级的数据对象。

强制存取控制方法提供了比自主存取控制方法更高层次的安全性。

5. 对下列两个关系模式：

学生(学号, 姓名, 年龄, 性别, 家庭住址, 班级号)

班级(班级号, 班级名, 班主任, 班长)

请用 SQL 的 GRANT 语句完成下列授权功能：

- ① 授予用户 U1 拥有两个表的所有权限，并可向其他用户授权。
- ② 授予用户 U2 对“学生”表具有查看权限，对“家庭住址”具有更新权限。
- ③ 将“班级”表的查看权限授予所有用户。

- ④ 将“学生”表的查询、更新权限授予角色 R1。
- ⑤ 将角色 R1 授予用户 U1, 并且 U1 可继续向其他角色授权。

答:

- ① GRANT ALL PRIVILEGES ON TABLE 学生, 班级 TO U1 WITH GRANT OPTION;
- ② GRANT SELECT, UPDATE(家庭住址) ON TABLE 学生 TO U2;
- ③ GRANT SELECT ON TABLE 班级 TO PUBLIC;
- ④ CREATE ROLE R1;
GRANT SELECT, UPDATE ON TABLE 学生 TO R1;
- ⑤ GRANT R1 TO U1 WITH ADMIN OPTION;

6. 今有两个关系模式:

职工(职工号, 姓名, 年龄, 职务, 工资, 部门号)

部门(部门号, 名称, 经理名, 地址, 电话号)

请用 SQL 的 GRANT 语句(加上视图机制)完成以下授权定义或存取控制功能:

- ① 用户王明对两个表有 SELECT 权限。
GRANT SELECT ON TABLE 职工, 部门 TO 王明;
- ② 用户李勇对两个表有 INSERT 和 DELETE 权限。
GRANT INSERT, DELETE ON TABLE 职工, 部门 TO 李勇;
- ③ 每个职工只对自己的记录有 SELECT 权限。

GRANT SELECT ON TABLE 职工 WHEN USER()=NAME TO ALL;

【解析】这里的 GRANT 语句支持 WHEN 子句和 USER()的使用。用户要将自己的名字作为 ID。注意, 在不同的系统中这些扩展语句可能有所不同, 读者练习时应了解自己所使用的 DBMS 产品的扩展语句。

- ④ 用户刘星对职工表有 SELECT 权限, 对工资字段具有更新权限。

GRANT SELECT, UPDATE(工资) ON TABLE 职工 TO 刘星;

- ⑤ 用户张新具有修改这两个表的结构权限。

GRANT ALTER TABLE ON TABLE 职工, 部门 TO 张新;

- ⑥ 用户周平具有对两个表的所有权限(读、插、改、删数据), 并具有给其他用户授权的权限。

GRANT ALL PRIVILEGES ON TABLE 职工, 部门 TO 周平 WITH GRANT OPTION;

- ⑦ 用户杨兰具有查询每个部门职工的最高工资、最低工资和平均工资的权限, 但是她不能查看每个人的工资。

首先建立一个视图, 存放每个部门的最高工资、最低工资和平均工资:

```
CREATE VIEW 部门工资 AS
SELECT 部门.部门号, 部门.名称, MAX(工资), MIN(工资), AVG(工资)
FROM 职工, 部门
```

WHERE 职工.部门号 = 部门.部门号

GROUP BY 部门.部门号;

然后,把查询这个视图的权限授予杨兰:

GRANT SELECT ON 部门工资 TO 杨兰;

7. 针对上面第6题中第①~⑦题的每一种情况,撤销各用户所授予的权限。

答:

① REVOKE SELECT ON TABLE 职工, 部门 FROM 王明;

② REVOKE INSERT, DELETE ON TABLE 职工, 部门 FROM 李勇;

③ REVOKE SELECT ON TABLE 职工 WHEN USER()= NAME FROM ALL;

④ REVOKE SELECT, UPDATE(工资) ON TABLE 职工 FROM 刘星;

⑤ REVOKE ALTER TABLE ON TABLE 职工, 部门 FROM 张新;

⑥ REVOKE ALL PRIVILEGES ON TABLE 职工, 部门 FROM 周平;

【解析】语句 REVOKE ALL PRIVILEGES ON TABLE 职工, 部门 FROM 周平 CASCADE; 收回了用户周平的所有权限,同时,级联收回了周平授予其他用户在职工和部门表上的权限。

⑦ REVOKE SELECT ON 部门工资 FROM 杨兰;

【解析】原来杨兰使用的视图,是否也要删除呢?即 DROP VIEW 部门工资;应该由创建该视图的用户或 DBA 来确定。

8. 理解并解释强制存取控制机制中主体、客体、敏感度标记的含义。

答:请阅读《概论》第4章4.2.6小节“强制存取控制方法”相关内容。

主体是系统中的活动实体,既包括 DBMS 所管理的实际用户,也包括代表用户的各进程。客体是系统中的被动实体,是受主体操纵的,包括文件、基本表、索引、视图等。

对于主体和客体,DBMS 为它们每个实例(值)指派一个敏感度标记。敏感度标记被分成若干级别,例如,绝密级、机密级、秘密级、公开等。主体的敏感度标记称为许可证级别,客体的敏感度标记称为密级。

9. 举例说明强制存取控制机制如何确定主体能否存取客体。

答:假设要对关系变量 S 进行强制存取控制,为简化起见,假设要控制存取的数据单元是元组,则每个元组标以密级,如下表所示(4=绝密,3=机密,2=秘密):

SNO	SNAME	STATUS	CITY	CLASS
S1	Smith	20	London	2
S2	Jones	10	Paris	3
S3	Clark	20	London	4

假设系统的存取规则是:

① 仅当主体的许可证级别大于或等于客体的密级时,才能读取相应的客体。

② 仅当主体的许可证级别小于或等于客体的密级时,才能写相应的客体。

如果用户 U1 和 U2 的许可证级别分别为 3 和 2,则根据规则,用户 U1 能读取元组 S1 和 S2,并且可修改元组 S2;用户 U2 只能读取和修改元组 S1。

10. 什么是数据库的审计功能,为什么要提供审计功能?

答:请阅读《概论》第 4 章 4.4 节“审计”相关内容。

【解析】审计是 DBMS 提供了一种事后检查的安全机制,即在用户对数据库执行操作的同时,所有这些操作会被自动记录到系统的审计日志中。审计员可以根据审计日志中记录的信息,分析和重现导致数据库现状的一系列事件,找出非法存取数据的人员、时间和内容等。

4.3 补充习题

1. 选择题

① 强制存取控制策略是 TCSEC/TDI 哪一级安全级别的特色? ()

A. C1 B. C2 C. B1 D. B2

② SQL 的 GRANT 和 REVOKE 语句可以用来实现 ()。

A. 自主存取控制 B. 强制存取控制
C. 数据库角色创建 D. 数据库审计

③ 在强制存取控制机制中,当主体的许可证级别等于客体的密级时,主体可以对客体进行的操作是 ()。

A. 读取 B. 写入
C. 不可操作 D. 读取、写入

2. 填空题

① 数据库安全技术包括用户身份鉴别、_____、_____、_____和数据加密存储和加密传输等。

② 在数据加密技术中原始数据通过某种加密算法变换为不可直接识别的格式,称为_____。

③ 数据库角色实际上是一组与数据库操作相关的各种_____。

④ 在对用户授予列 INSERT 权限时,一定要包含对_____的 INSERT 权限,否则用户的插入会因为空值被拒绝。除了授权的列,其他列的值或者取_____,或者为_____。